SPESIFIKASI KEBUTUHAN PERANGKAT LUNAK (SKPL)
APLIKASI UMKM PENJUALAN SAYURAN SEGAR
KELOMPOK - 3

Anggota kelompok:

20231310046	M. Irvan Alfiansyah
20231310047	M. Nur Yanfa
20231310061	Ilham Ramdan

PROGRAM STUDI TEKNIK INFORMATIKA
UNIVERSITAS KEBANGSAAN REPUBLIK INDONESIA
Jln. Terusan Halimun No. 37 (Pelajar Pejuang 45) Lingkar Selatan Kec. Lengkong kota Bandung Jawa Barat 40263

DAFTAR PERUBAHAN

Revisi	Deskripsi
A	**Versi pertama — dokumen SKPL Aplikasi UMKM Sayuran Segar**
B	
C	
D	
E	
F	
G	

Index	A	B	C	D	E	F	G
TGL							
Ditulis Oleh	M. Irvan Alfiansyah						
Diperiksa Oleh	M. Nur Yanfa						
Disetujui Oleh	Ilham Ramdan						

DAFTAR HALAMAN PERUBAHAN

HALAMAN	REVISI	HALAMAN	REVISI

DAFTAR ISI

Contents

I. Pendahuluan 5

1.1 Tujuan Penulisan Dokumen 5

1.2 Lingkup Masalah 5

1.3 Definisi dan Istilah 6

1.4 Aturan Penamaan dan Penomoran 7

1.5 Referensi 8

1.6 Ikhtisar Dokumen 8

1.7 Kebutuhan Non-Fungsional 9
II. DESKRIPSI PERANCANGAN GLOBAL 9

II. DESKRIPSI PERANCANGAN GLOBAL

2.1 Rancangan Lingkungan Implementasi

Sistem Aplikasi E-Commerce UMKM Sayuran Segar ini dirancang secara khusus untuk beroperasi pada lingkungan implementasi terdistribusi modern yang menerapkan prinsip pemisahan secara mutlak antara antarmuka pengguna di sisi klien (*frontend*) dan komputasi logika bisnis di sisi peladen (*backend*) . Pemisahan arsitektur (*decoupled architecture*) ini merupakan keputusan strategis untuk mempermudah audit keamanan, mempercepat pelokalan *bug* (cacat perangkat lunak), serta memungkinkan tim jaminan mutu (QA) melakukan pengujian beban (*load testing*) pada peladen secara independen tanpa dipengaruhi oleh performa *rendering* visual di peramban pengguna.

Pada lapisan antarmuka visual, sistem mengasumsikan keberadaan aplikasi *Single Page Application* (SPA) berbasis pustaka React.js yang merepresentasikan etalase *marketplace* fungsional kelas industri. Antarmuka ini bertugas menangani interaksi dom (*Document Object Model*) dan navigasi pengguna secara dinamis, untuk kemudian berkomunikasi dengan pusat data melalui permintaan HTTP asinkronus.

Beralih pada sisi peladen, komputasi logika bisnis sepenuhnya digerakkan oleh bahasa pemrograman Go (Golang) versi 1.20 atau yang lebih baru. Golang dipilih sebagai tulang punggung arsitektur karena keunggulannya dalam mengelola ribuan eksekusi proses secara paralel (*concurrency*) melalui *Goroutine* dengan konsumsi alokasi memori yang sangat efisien. Ekosistem peladen ini ditopang oleh kerangka kerja jaringan *Gin Web Framework* untuk memfasilitasi titik rute API yang sangat cepat, serta pustaka *Object-Relational Mapping* (GORM) untuk menerjemahkan struktur objek ke dalam relasi basis data sekaligus melakukan sanitasi kueri otomatis guna menangkal ancaman *SQL Injection*. Sementara itu, pangkalan data dikelola menggunakan sistem manajemen basis data relasional PostgreSQL versi 15. PostgreSQL diimplementasikan sebagai fondasi penyimpanan absolut karena kepatuhannya terhadap standar transaksi ACID (*Atomicity, Consistency, Isolation, Durability*) dan kapabilitas *Multi-Version Concurrency Control* (MVCC) yang sangat krusial dalam ekosistem *e-commerce*.

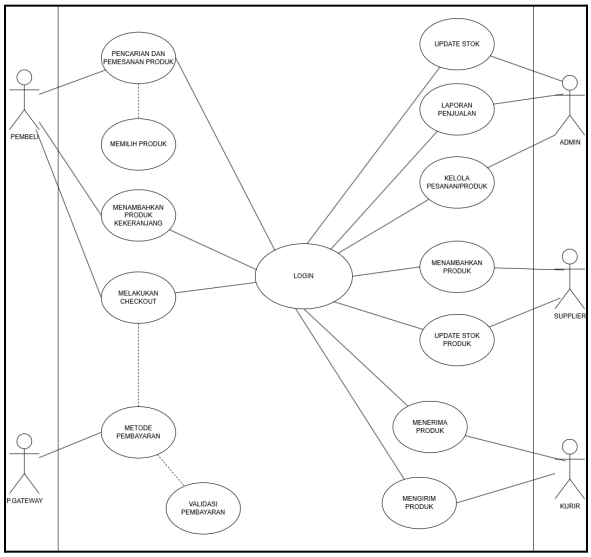
2.2 Model Proses Berbasis Objek

Pemodelan proses perangkat lunak pada sistem ini mengadaptasi paradigma berorientasi objek yang diselaraskan secara ketat dengan prinsip *Clean Architecture*. Pendekatan ini

memastikan bahwa setiap entitas bisnis dan alur kerja di dalam ekosistem rantai pasok UMKM direpresentasikan sebagai objek mandiri yang memiliki tanggung jawab tunggal (*Single Responsibility Principle*).

2.2.1 Diagram Use Case

Sistem mengakomodasi dan membatasi interaksi fungsional lintas-sektoral melalui lima aktor utama yang masing-masing dikurung dalam ruang lingkup kewenangan terisolasi .



- Aktor Pembeli: Pengguna akhir di hilir rantai pasok yang memiliki otoritas untuk menavigasi katalog sayuran, memanipulasi keranjang belanja, mengeksekusi komitmen pemesanan komersial (*checkout*), serta melacak status perjalanan barang yang diantar secara waktu nyata.
- Aktor Admin: Entitas pengawas ekosistem yang dilindungi oleh perlindungan perantara (*Role-Based Access Control*). Admin memiliki hak istimewa (*privilege*) untuk memonitor lalu lintas transaksi finansial, mengelola referensi kategori induk, dan melakukan intervensi moderasi terhadap data pengguna maupun katalog apabila terdeteksi pelanggaran.

- Aktor Supplier (Petani/Pengepul): Produsen komoditas di hulu rantai pasok yang berwenang untuk mendaftarkan hasil panen mereka secara mandiri ke dalam platform. Sistem secara komputasional mengunci kewenangan mereka sehingga seorang Supplier hanya mampu mengubah harga jual dan kuantitas stok untuk produk yang mereka tautkan dengan identitas akun mereka sendiri (*Ownership Protection*).

- Aktor Kurir: Entitas logistik operasional yang bertugas memindahkan wujud fisik komoditas. Melalui antarmuka API, Kurir berwenang memperbarui titik pelacakan barang (seperti 'Dikemas', 'Diantar', hingga 'Diterima oleh Pembeli') khusus untuk manifes pesanan yang telah ditugaskan kepadanya.

- Aktor Payment Gateway (Midtrans): Satu-satunya aktor berupa mesin eksternal yang diizinkan untuk mengintervensi status pesanan aplikasi. Aktor ini berinteraksi secara asinkronus dengan menembakkan muatan data berformat JSON (*Webhook*) ke rute khusus di peladen Golang guna menginformasikan perubahan status pelunasan transaksi.

Berikut adalah narasi detail untuk lima use case utama sistem. Setiap use case mencantumkan precondition, main flow, alternative flow, dan postcondition sebagai dasar perancangan test case.

UC-01: Login Pengguna

Kode UC	UC-01
Nama	Login Pengguna (Autentikasi JWT)
Aktor	Pembeli, Admin, Supplier, Kurir
Deskripsi	Pengguna memasukkan kredensial email dan password untuk mendapatkan JWT yang digunakan sebagai bukti identitas pada seluruh endpoint terproteksi.
Precondition	1. Pengguna telah terdaftar di tabel users dengan email unik.2. Password tersimpan dalam format hash bcrypt (cost 14).3. Endpoint POST /api/v1/auth/login dapat diakses tanpa token (public route).
Main Flow	1. Pengguna mengirim POST /api/v1/auth/login dengan payload {email, password}.2. Sistem menjalankan query SELECT WHERE email=? (GORM, parameterized).3. Sistem menjalankan bcrypt.CompareHashAndPassword().4. Sistem membuat JWT berisi {id_user, role}, TTL 24 jam, signed dengan secret key.5. Sistem mengembalikan HTTP 200 OK dengan {token, role, expires_in}.
Alt Flow A	A1 (email tidak ditemukan): Langkah 2 mengembalikan nil → sistem return 401 Unauthorized dengan pesan "Email atau password salah" (pesan generik untuk mencegah user enumeration).
Alt Flow B	B1 (password salah): Langkah 3 gagal → sistem return 401 Unauthorized.
Postcondition	Sukses: Pengguna memegang JWT valid selama 24 jam dan dapat mengakses endpoint sesuai role.Gagal: Tidak ada token diterbitkan. Percobaan gagal dicatat LoggerMiddleware.

UC-02: Checkout dan Penguncian Stok ACID

Kode UC	UC-02
Nama	Checkout dan Penguncian Stok (ACID Transaction)
Aktor	Pembeli (autentikasi JWT role=pembeli)
Deskripsi	Pembeli menyelesaikan proses pembelian. Sistem mengunci stok secara atomik menggunakan row-level locking untuk mencegah overselling, lalu membuat pesanan dan token pembayaran Midtrans.
Precondition	1. Pembeli telah login dan memiliki JWT valid.2. Tabel keranjang milik pembeli tidak kosong.3. Stok seluruh produk di keranjang mencukupi jumlah yang dipesan.4. Koneksi ke Midtrans Snap API aktif.
Main Flow	1. Pembeli mengirim POST /api/v1/orders/checkout (JWT di header).2. Sistem membuka transaksi database: tx.Begin().3. Sistem mengunci baris produk: SELECT stok FROM produk WHERE id=? FOR UPDATE.4. Sistem memvalidasi stok tersedia >= kuantitas keranjang.5. Sistem menghitung total_tagihan dan membuat record di tabel pesanan.6. Sistem membuat record di tabel pembayaran (status PENDING, snap_token).7. Sistem mengurangi stok produk (UPDATE produk SET stok=stok-qty).8. Sistem menghapus item dari tabel keranjang.9. Sistem memanggil Midtrans Snap API untuk mendapatkan snap_token.10. Sistem COMMIT transaksi dan return HTTP 201 Created + snap_token.

Alt Flow A	A1 (stok tidak cukup - langkah 4): Sistem ROLLBACK seluruh transaksi → return HTTP 400 Bad Request + detail produk yang stoknya kurang. Tidak ada perubahan apapun di database.
Alt Flow B	B1 (Midtrans error - langkah 9): Sistem ROLLBACK seluruh transaksi → return HTTP 502 Bad Gateway. Stok tidak berkurang, pesanan tidak dibuat.
Alt Flow C	C1 (race condition - concurrent checkout): SELECT FOR UPDATE memblokir transaksi lain pada baris produk yang sama. Transaksi pertama selesai, transaksi berikutnya mendapat stok yang sudah berkurang dan masuk Alt Flow A jika tidak mencukupi.
Postcondition	Sukses: Record pesanan dan pembayaran tersimpan, stok berkurang, keranjang kosong, snap_token aktif untuk pembayaran.Gagal: Tidak ada perubahan di database (rollback total).

UC-03: Rekonsiliasi Pembayaran via Webhook Midtrans

Kode UC	UC-03
Nama	Rekonsiliasi Pembayaran Asinkronus (Webhook Midtrans)
Aktor	Payment Gateway (Midtrans) — aktor eksternal otomatis
Deskripsi	Midtrans mengirimkan notifikasi HTTP POST ke peladen Golang setelah pembayaran berhasil/gagal. Sistem memvalidasi tanda tangan kriptografis dan memperbarui status pesanan secara atomik.
Precondition	1. Pesanan berstatus PENDING di tabel pesanan.2. Server key Midtrans terkonfigurasi di environment peladen.3. Endpoint POST /api/v1/payments/webhook dapat diakses publik (tidak perlu JWT).
Main Flow	1. Midtrans mengirim POST /api/v1/payments/webhook dengan payload JSON.2. Sistem mengekstrak: order_id, status_code, gross_amount, signature_key.3. Sistem merangkai string: SHA512(order_id + status_code + gross_amount + server_key).4. Sistem membandingkan hash lokal dengan signature_key dari Midtrans.5. Jika valid, sistem UPDATE pesanan SET status_pesanan=PAID WHERE id_pesanan=order_id.6. Sistem UPDATE pembayaran SET metode=?, waktu_lunas=NOW() WHERE id_pesanan=?.7. Sistem return HTTP 200 OK.
Alt Flow A	A1 (signature tidak valid - langkah 4): Sistem return 403 Forbidden. Status pesanan tidak berubah. Kejadian dicatat di log keamanan.
Alt Flow B	B1 (pesanan sudah PAID - idempotency): Sistem mendeteksi status sudah PAID, skip UPDATE, return 200 OK (idempotent — aman jika Midtrans retry).
Postcondition	Sukses: status_pesanan=PAID, waktu_lunas terisi, manifest pengiriman dapat dibuat.Gagal signature: Status pesanan tetap PENDING, insiden tercatat.

UC-04: Manajemen Produk oleh Supplier (dengan Proteksi IDOR)

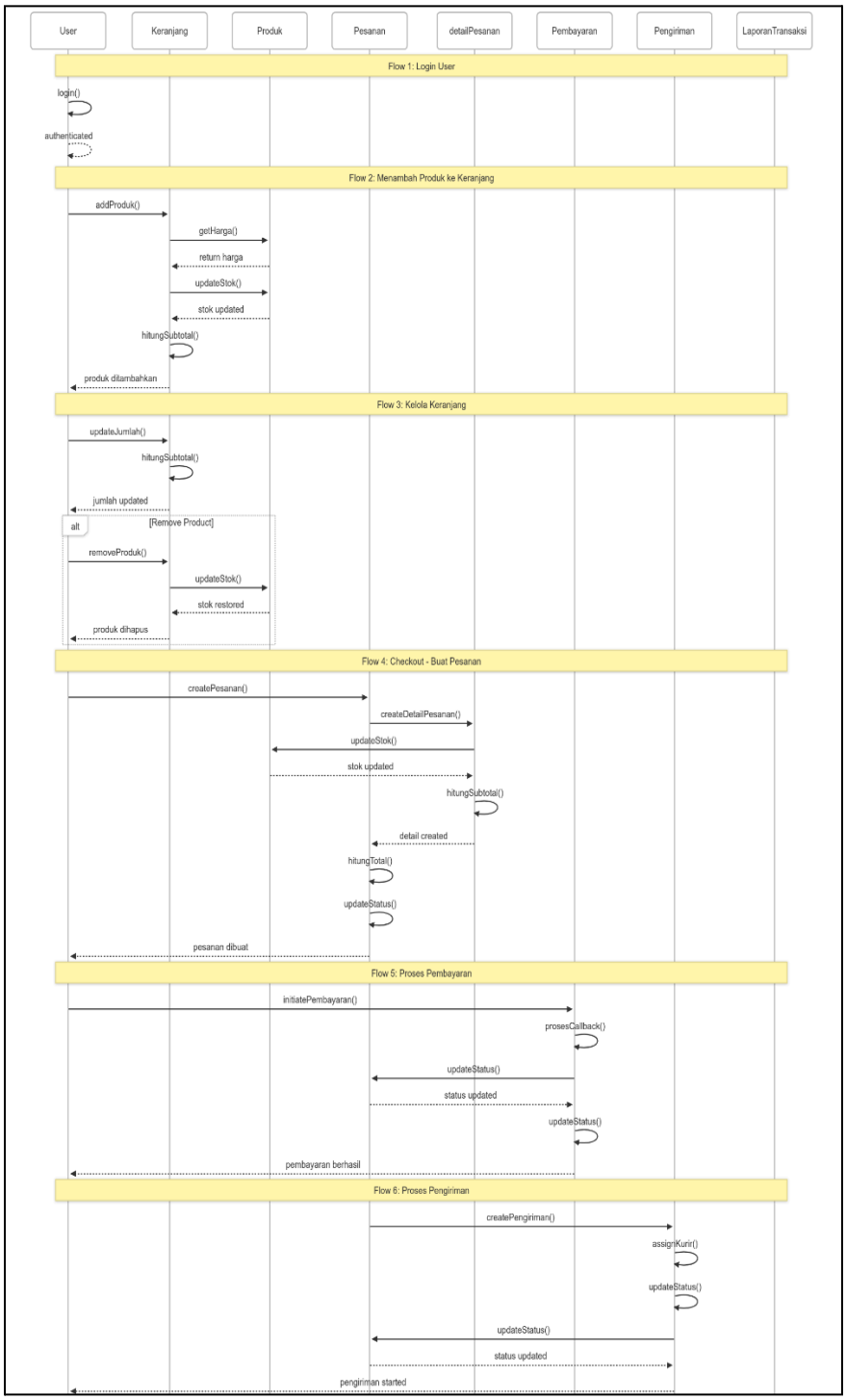
Kode UC	UC-04
Nama	Manajemen Produk Supplier (CRUD + Validasi IDOR)
Aktor	Supplier (autentikasi JWT role=supplier)
Deskripsi	Supplier mendaftarkan, memperbarui, atau menghapus produk miliknya. Sistem memvalidasi kepemilikan setiap operasi untuk mencegah Insecure Direct Object Reference (IDOR).

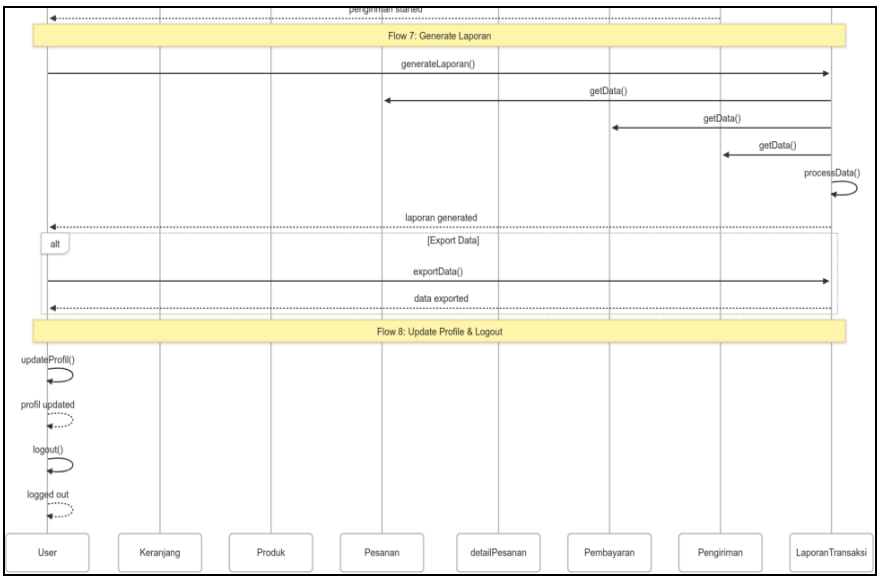
Precondition	1. Pengguna telah login dengan role=supplier.2. JWT valid dan belum expired.3. Untuk UPDATE/DELETE: produk dengan id_produk yang dituju harus ada di DB.
Main Flow	1. Supplier mengirim PUT /api/v1/products/:id_produk dengan payload {nama, harga, stok}.2. AuthMiddleware memvalidasi JWT → ekstrak id_user.3. RoleMiddleware memvalidasi role === "supplier".4. Sistem mencari produk: SELECT WHERE id_produk=? AND id_user=? (klausa id_user kritis!).5. Sistem memperbarui data produk.6. Sistem return HTTP 200 OK + data produk terbaru.
Alt Flow A	A1 (IDOR - produk bukan milik Supplier ini - langkah 4): Query mengembalikan nil karena klausa AND id_user=? tidak terpenuhi → sistem return 403 Forbidden + pesan "Akses ditolak: Anda bukan pemilik produk ini".
Alt Flow B	B1 (validasi input gagal): harga < 0 atau stok < 0 → sistem return 400 Bad Request + detail field yang invalid.
Postcondition	Sukses: Data produk ter-update di tabel produk.Gagal IDOR: Data produk tidak berubah, upaya tercatat di log audit.

UC-05: Pembaruan Status Pengiriman oleh Kurir

Kode UC	UC-05
Nama	Pembaruan Status Pengiriman (Logistik Kurir + Proteksi IDOR)
Aktor	Kurir (autentikasi JWT role=kurir)
Deskripsi	Kurir yang ditugaskan memperbarui status fisik pengiriman barang. Sistem memvalidasi bahwa Kurir yang melakukan request adalah Kurir yang ditugaskan pada manifest tersebut.
Precondition	1. Pengguna login dengan role=kurir.2. Manifest pengiriman sudah ada (dibuat setelah pesanan PAID).3. Kolom id_kurir di tabel pengiriman telah diisi oleh Admin.4. Status baru harus berupa salah satu nilai enum yang valid.
Main Flow	1. Kurir mengirim PATCH /api/v1/shipping/:id_pengiriman/status dengan {status_kirim}.2. AuthMiddleware memvalidasi JWT → ekstrak id_user Kurir.3. RoleMiddleware memvalidasi role === "kurir".4. Sistem mencari manifest: SELECT WHERE id_pengiriman=? AND id_kurir=?.5. Sistem memvalidasi nilai status_kirim ada dalam enum (DIKEMAS/DIKIRIM/DITERIMA).6. Sistem UPDATE pengiriman SET status_kirim=? WHERE id_pengiriman=?.7. Sistem return HTTP 200 OK + data pengiriman terbaru.
Alt Flow A	A1 (IDOR - Kurir bukan penanggung manifest ini - langkah 4): Query mengembalikan nil → sistem return 403 Forbidden.
Alt Flow B	B1 (status tidak valid - langkah 5): Nilai di luar enum → sistem return 400 Bad Request.
Postcondition	Sukses: status_kirim diperbarui, perubahan dapat dilacak pembeli.Gagal: Status tidak berubah, Kurir tidak sah tidak dapat memodifikasi manifest milik Kurir lain.

2.2.2 Diagram sequence





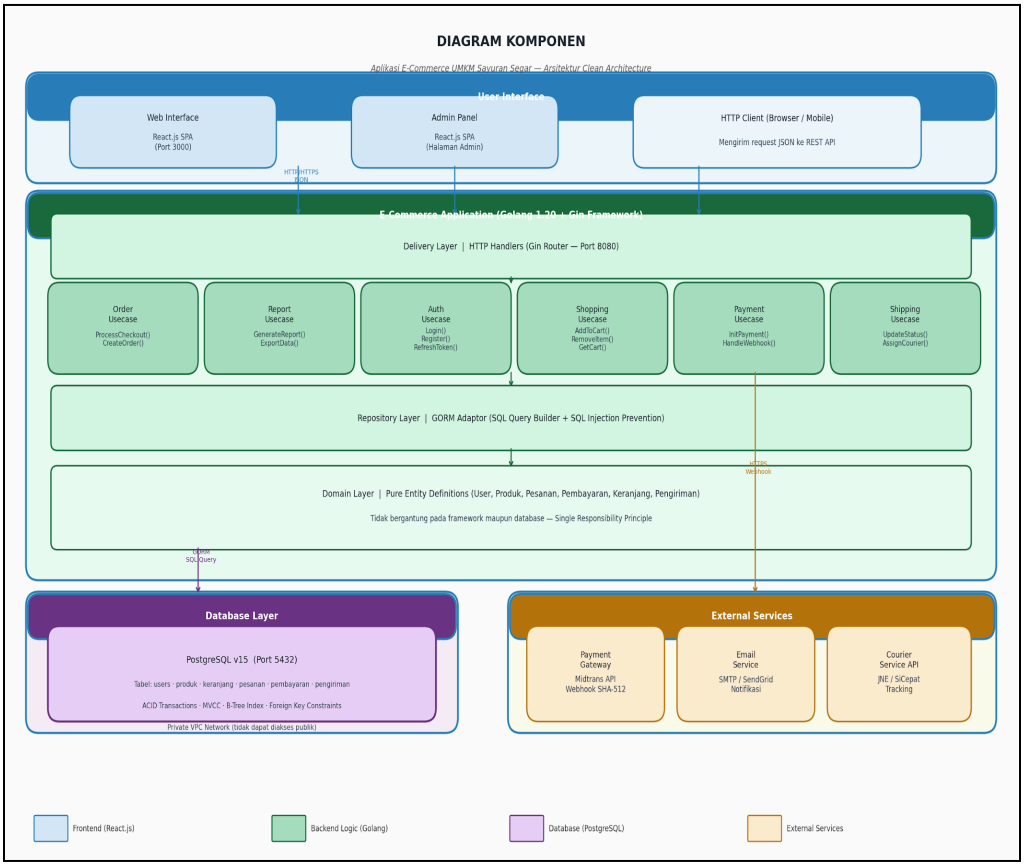
Pemodelan urutan interaksi objek difokuskan pada pembedahan tiga alur pemrosesan yang paling kompleks dan menduduki prioritas utama dalam matriks pengujian jaminan mutu (SQA) .

- Sequence Manipulasi Katalog oleh Supplier: Alur pelindungan objek ini mendemonstrasikan bagaimana peladen mencegat permintaan pembaruan produk dari klien, membongkar identitas asli Supplier dari token JWT, lalu membandingkannya dengan ID Pemilik produk di tabel basis data. Jika tidak identik, sistem secara proaktif menggugurkan proses (*abort*) dengan galat 403 *Forbidden*.
- Sequence Pemesanan ACID (Checkout): Alur transaksional yang mendemonstrasikan pembukaan gerbang blok transaksi di basis data. Sistem mengunci baris stok produk, memvalidasi kecukupan panen, menghitung total nilai keekonomian, menyisipkan data pesanan baru, dan mengeliminasi isi keranjang pembeli. Seluruh rangkaian instruksi ini dieksekusi sebagai satu kesatuan komputasi yang atomik.
- Sequence Validasi Notifikasi Midtrans: Alur keamanan sinkronisasi di mana peladen mengekstrak tanda tangan kriptografi bawaan Midtrans, memadukannya dengan parameter internal, lalu men- *hash* nilainya menggunakan algoritma SHA-512 untuk memastikan bahwa notifikasi pelunasan tersebut mutlak terhindar dari pemalsuan peretas.

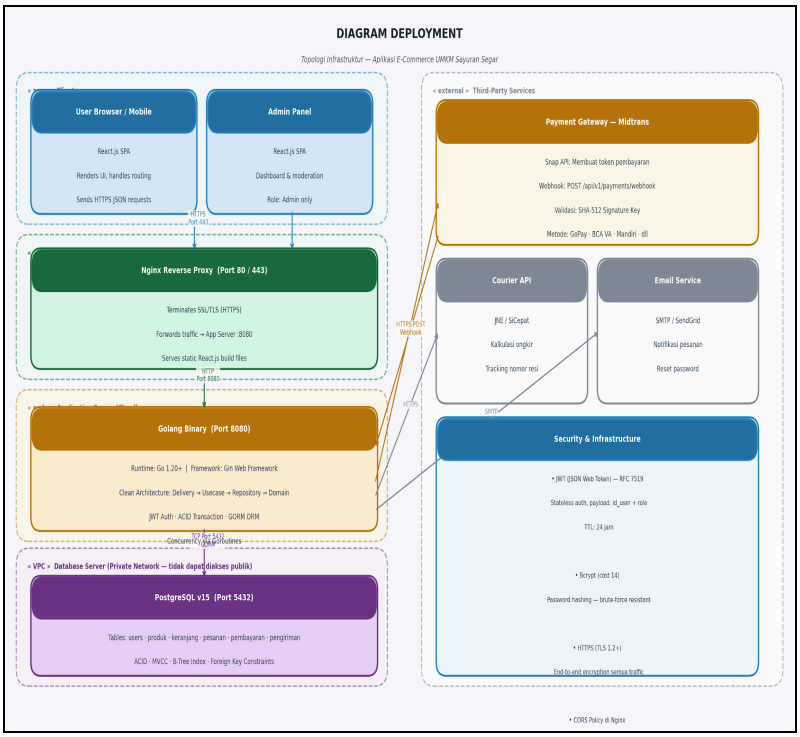
2.2.3 Diagram Implementasi

Implementasi fisik arsitektur dijabarkan melalui dua pemodelan diagram topologi teknis guna menegaskan pemisahan fokus (*Separation of Concerns*) secara absolut

A. Diagram komponen



- Pada **Diagram Komponen**, arsitektur kode peladen *backend* dibelah menjadi empat cincin isolasi. Cincin terluar adalah *Delivery* (HTTP Handlers) yang murni memvalidasi lalu lintas JSON. Cincin kedua adalah *Usecase* (Logika Bisnis) tempat otak komputasi berjalan. Cincin ketiga adalah *Repository* yang berfungsi sebagai adaptor kueri GORM. Cincin inti adalah *Domain* yang memuat pendefinisian entitas murni.**Diagram deployment**



- Pada **Diagram Deployment (Penempatan)**, topologi sistem mendistribusikan beban ke berbagai simpul komputasi: Peramban klien merender SPA React.js, peladen *Application Server* di *cloud* mengeksekusi *binary runtime* Golang di porta 8080, dan *Database Server* ditempatkan pada jaringan privat tertutup (VPC) yang mengeksekusi mesin PostgreSQL di porta 5432.

2.3 Model Data

Perancangan arsitektur pemodelan data pada sistem disusun untuk merajut ekosistem relasional yang mampu memfasilitasi arus informasi dari hulu (suplai) ke hilir (pengiriman) secara konsisten, tanpa memicu anomali duplikasi data

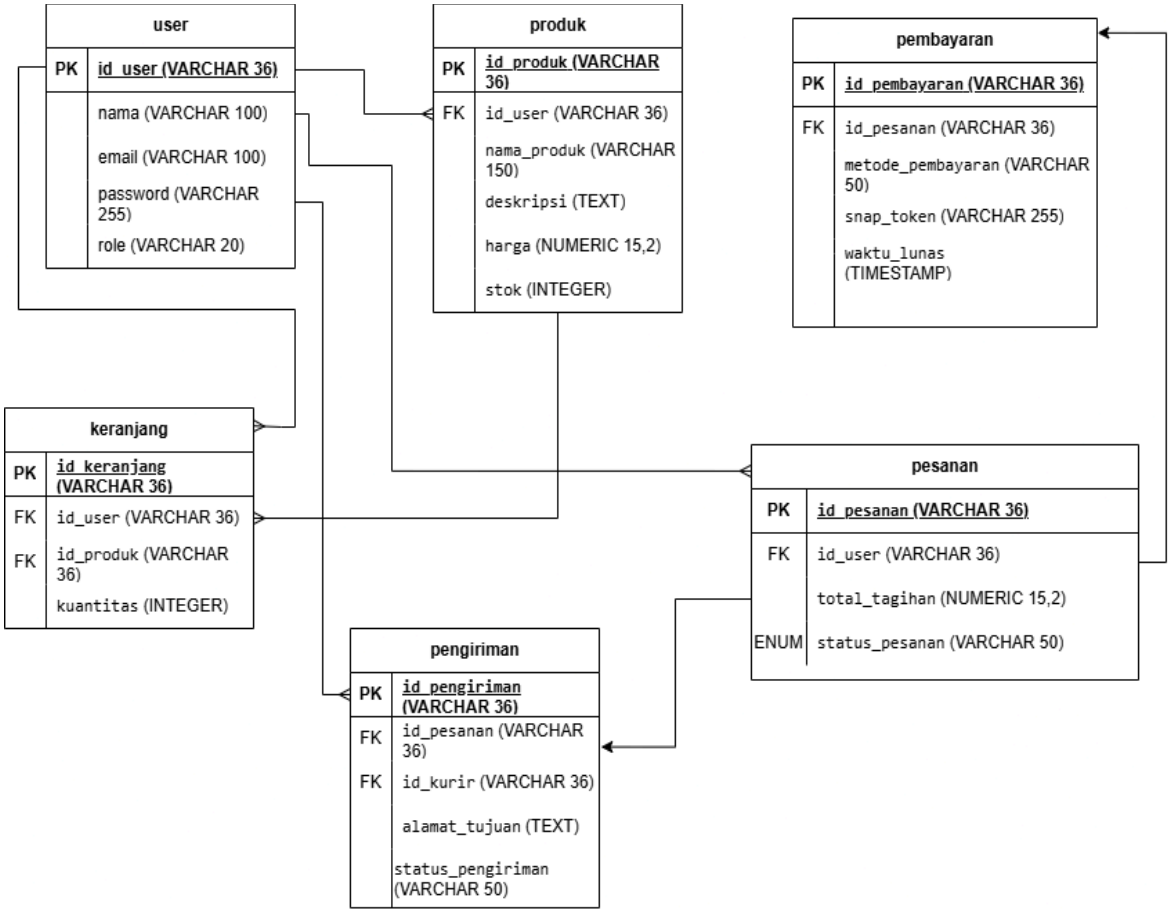
2.3.1 Definisi Domain/Type

Bahasa pemrograman Golang beroperasi dengan pengetikan statis yang sangat kaku, sedangkan PostgreSQL memiliki variasi spektrum tipe data relasional yang luas. Untuk itu, sistem mewajibkan pemetaan kamus tipe data secara eksplisit guna menangkal galat alokasi memori

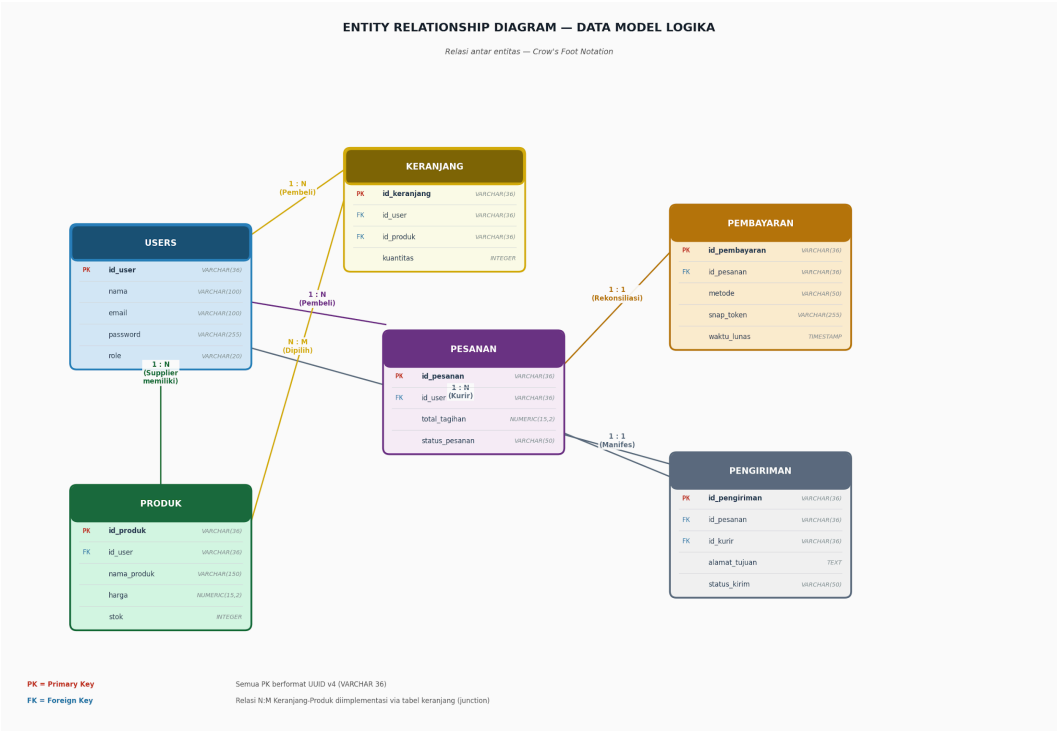
Nama Domain	Format di Golang	Format di PostgreSQL	Keterangan Teknis Penggunaan
Identitas Baris	string	VARCHAR(36)	Standar UUID untuk mencegah tabrakan ID lintas-aktor.
Nilai Finansial	float64	NUMERIC(15,2)	Presisi ganda agar tagihan bebas dari galat pembulatan desimal.
Satuan Barang	int	INTEGER	Mewakili entitas fisik sayuran yang komputasinya tidak bisa dipecah.
Jejak Waktu	time.Time	TIMESTAMP	Perekaman waktu audit absolut (presisi hingga milidetik).

2.3.2 Data Model Logika

Berdasarkan hasil analisis rekayasa proses bisnis di lapangan, model data logika dirangkai di atas fondasi enam entitas utama yang terikat melalui hukum kardinalitas yang sangat ketat . Entitas **User** menjadi pusaran identitas yang mewadahi kredensial semua aktor. Dari hulu, entitas **User** (bertindak sebagai Supplier) memancarkan relasi kepemilikan ke banyak entitas **Produk**. Di sektor tengah, entitas **Produk** menjadi acuan relasional bagi entitas **Keranjang** (sebagai ruang tunggu sirkulasi) dan **Pesanan** (sebagai bukti komitmen finansial). Di sektor hilir, setiap entitas **Pesanan** yang sukses akan melahirkan satu relasi koheren ke entitas **Pembayaran** (sebagai rekonsiliasi Midtrans) dan satu relasi logistik ke entitas **Pengiriman** yang diikatkan kepada entitas **User** (bertindak sebagai Kurir).



ERD berikut menggambarkan relasi antar entitas menggunakan notasi Crow's Foot, lengkap dengan jenis relasi (1:1, 1:N, N:M) dan atribut kunci:



Gambar 2.3.2 — Entity Relationship Diagram (Data Model Logika, Crow's Foot Notation)

Keterangan relasi utama:

USERS (1) → PRODUK (N): Satu Supplier dapat mendaftarkan banyak produk. Enforced via id_user FK di tabel produk.

USERS (1) → KERANJANG (N): Satu Pembeli dapat memiliki banyak item di keranjang. Setiap baris keranjang mewakili satu jenis sayuran.

USERS (1) → PESANAN (N): Satu Pembeli dapat membuat banyak pesanan. Setiap pesanan adalah snapshot finansial permanen (tidak dapat dihapus).

PESANAN (1) → PEMBAYARAN (1): Relasi satu-ke-satu. Satu pesanan tepat punya satu record rekonsiliasi finansial di Midtrans.

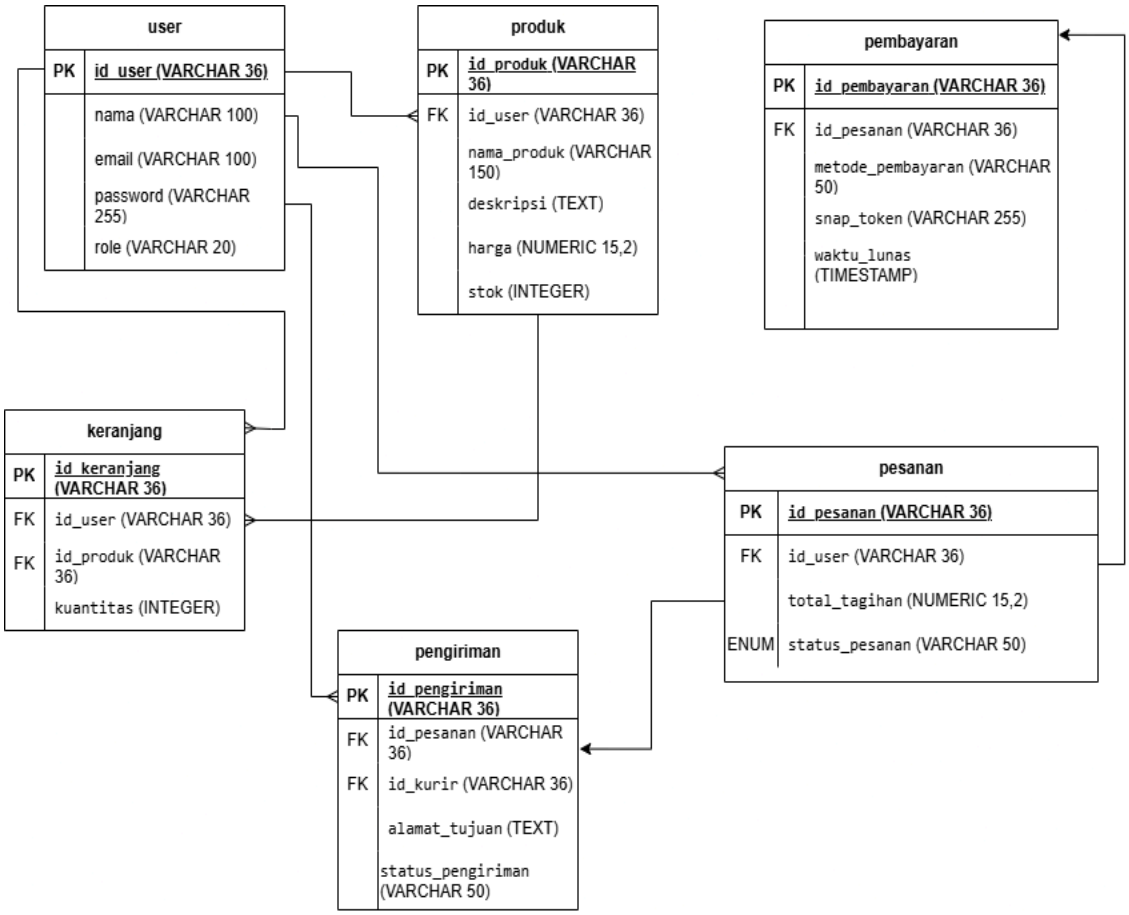
PESANAN (1) → PENGIRIMAN (1): Relasi satu-ke-satu. Manifest pengiriman dibuat setelah pesanan berstatus PAID.

PRODUK (N) ↔ KERANJANG (M): Relasi banyak-ke-banyak diimplementasi melalui tabel keranjang sebagai junction table.

2.3.3 Data Model Fisik

Model data fisik adalah manifestasi teknis dari rancangan logika ke dalam skema struktur tabel di mesin PostgreSQL . Konfigurasi fisik ini menegakkan integritas referensial melalui batasan Kunci Tamu (*Foreign Key Constraints*) secara radikal. Sebagai contoh, peladen

melarang keras eksekusi penghapusan terhadap sebuah entitas produk apabila produk tersebut statusnya masih bertengger di dalam tabel pengiriman yang belum selesai diantar oleh kurir (*Restrict Delete Cascade*). Pada lapisan optimasi, model fisik ini menerapkan teknik *B-Tree Indexing* pada kolom alamat surel untuk memastikan waktu pencarian data kredensial tidak melebihi ambang batas puluhan milidetik.



2.3.4 daftar tabel aplikasi

Rincian katalog relasional di bawah ini dibangun secara otomasi oleh mesin migrasi GORM untuk menopang keseluruhan siklus operasional komersial dan skenario pengujian aplikasi

Nama Tabel	Primary Key	Data Store	E/R	Spesifikasi Deskripsi Isi Tabel
users	id_user	PostgreSQL	Ya	Penyimpan profil sentral seluruh aktor. Dilindungi kriptografi sandi mutakhir (*bcrypt*).
produk	id_produk	PostgreSQL	Ya	Etalase komersial berisi rincian harga, stok aktual panen, dan tautan kepemilikan Supplier.
keranjang	id_keranjang	PostgreSQL	Ya	Penahan antrean transaksional sementara pembeli sebelum menuju kalkulasi *checkout*.
pesanan	id_pesanan	PostgreSQL	Ya	Arsip komitmen transaksi absolut yang merekam tagihan finansial dan perjalanan status.
pembayaran	id_pembayaran	PostgreSQL	Ya	Log rekonsiliasi finansial yang beroperasi asinkronus menyinkronkan respons peladen Midtrans.
pengiriman	id_pengiriman	PostgreSQL	Ya	Entitas manifest logistik yang mengikat alamat pembeli dengan pergerakan pelacakan kurir.

III. DESKRIPSI PERANCANGAN RINCI

Bagian ini menguraikan secara komprehensif spesifikasi struktur penyimpanan fisik pada tingkat basis data, rancangan kontrak antarmuka pemrograman aplikasi (API), serta algoritma pemrosesan logika bisnis yang dieksekusi oleh peladen *backend* Golang . Mengingat arsitektur sistem ini mengadopsi pemisahan (*decoupled*) antara *Frontend* dan *Backend*, spesifikasi komponen layar visual (*UI components*) direpresentasikan melalui spesifikasi titik akhir jaringan (*API Endpoints*), muatan data (*JSON Payload*), dan perantara keamanan (*Middleware*). Perancangan rinci ini menjadi pedoman mutlak bagi pengembang sumber kode dan acuan bagi insinyur jaminan mutu (QA) dalam menyusun matriks pengujian fungsional dan keamanan (SQA).

3.1 Deskripsi Rinci Tabel

Setiap tabel yang telah didefinisikan pada rancangan arsitektur data global (Bab II) dirinci satu per satu pada bagian ini untuk menjelaskan tipe data fisik, panjang karakter alokasi memori, serta aturan batasan (*constraints*) yang ditegakkan secara absolut oleh mesin PostgreSQL .

3.1.1 Tabel User

Identifikasi/Nama: users

Deskripsi Isi: Tabel sentral yang bertugas mengamankan profil kredensial seluruh entitas pengguna (Admin, Pembeli, Supplier, dan Kurir). Atribut sandi disamarkan menggunakan kriptografi *bcrypt* (*cost* 14) untuk mencegah kebocoran teks terang (*plaintext*).

Jenis: Tabel Data Induk Kredensial

Volume: Diperkirakan 10.000+ baris data. **Laju:** Moderat, estimasi 50-100 pendaftaran per hari.

Primary Key: id_user

Id Field	**Deskripsi**	**Tipe & Length**	**Boleh NULL**	**Default**	**Keterangan**
id_user	Identitas unik	VARCHAR(36)	NO	UUIDv4	Mencegah eksploitasi IDOR.
nama	Nama lengkap	VARCHAR(100)	NO	-	Wajib diisi pengguna.
email	Alamat surel	VARCHAR(100)	NO	-	Indeks Unik (B-Tree).
password	Sandi enkripsi	VARCHAR(255)	NO	-	Hasil komputasi *bcrypt*.
role	Hak akses otorisasi	VARCHAR(20)	NO	'pembeli'	Nilai: pembeli, admin, supplier, kurir.

3.1.2 Tabel Produk

Identifikasi/Nama: Produk

Deskripsi Isi: Tabel katalog komersial yang menyimpan rincian harga, deskripsi sayuran, dan pelacakan kuantitas stok panen yang diperbarui secara langsung oleh Supplier di hulu rantai pasok.

Volume: Sedang, berkisar 1.000 - 5.000 baris.

Jenis: Tabel Data Induk dan Dinamis

Laju: Pembaruan kolom stok terjadi sangat cepat mengikuti arus pesanan.

Primary Key: id_produk

Spesifikasi Kolom Tabel Produk:

Id Field	**Deskripsi**	**Tipe & Length**	**Boleh NULL**	**Default**	**Keterangan**

id_produk	Identitas sayuran	VARCHAR(36)	NO	UUIDv4	Kunci primer UUID.
id_user	Pemilik (Supplier)	VARCHAR(36)	NO	-	*Foreign Key* ke users.
nama_produk	Judulkomoditas	VARCHAR(150)	NO	-	Deskripsi nama sayuran.
deskripsi	Info tambahan	TEXT	YES	NULL	Penjelasan spesifikasi/panen.
harga	Harga jual akhir	NUMERIC(15,2)	NO	-	Presisi mata uang mutlak.
stok	Ketersediaan	INTEGER	NO	0	Dilarang bernilai minus (< 0).

3.1.3 Tabel Keranjang

- **Identifikasi/Nama:** keranjang
- **Deskripsi Isi:** Tabel transaksional sementara yang bertindak sebagai antrean ruang tunggu. Menampung rincian produk yang dipilih pembeli sebelum mereka mengeksekusi perjanjian transaksi finansial final.
- **Jenis:** Tabel Data Transaksi Sementara
- **Volume:** Tinggi dan sangat fluktuatif.
- **Laju:** Sangat cepat untuk komputasi penyisipan dan penghapusan fisik.
- **Primary Key:** id_keranjang

Id Field	**Deskripsi**	**Tipe & Length**	**Boleh NULL**	**Default**	**Keterangan**
id_keranjang	Identitas antrean	VARCHAR(36)	NO	UUIDv4	Kunci primer UUID.
id_user	Pemilik keranjang	VARCHAR(36)	NO	-	*Foreign Key* ke users (Pembeli).
id_produk	Sayuran terpilih	VARCHAR(36)	NO	-	*Foreign Key* ke produk.

kuantitas	Jumlah barang	INTEGER	NO	1	Minimal bernilai 1.

3.1.4 Tabel Pesanan

- Identifikasi/Nama: pesanan
- Deskripsi Isi: Tabel arsip permanen yang mencatat riwayat akhir transaksi berstandar ACID. Menyimpan komitmen total tagihan pembayaran dan menjejaki status makro dari perjalanan komoditas.
- Jenis: Tabel Data Transaksi Permanen
- Volume: Tinggi, diproyeksikan 50.000+ baris per bulan.
- Laju: Pertumbuhan akumulatif cepat tanpa ada penghapusan data.
- Primary Key: id_pesanan

Id Field	Deskripsi	Tipe & Length	Boleh NULL	Default	Keterangan
id_pesanan	Nomor resi transaksi	VARCHAR(36)	NO	UUIDv4	Identitas pesanan global.
id_user	Pemilik pesanan	VARCHAR(36)	NO	-	*Foreign Key* ke users (Pembeli).
total_tagihan	Nominal bersih	NUMERIC(15,2)	NO	-	Kalkulasi absolut oleh peladen.
status_pesanan	Transisi status	VARCHAR(50)	NO	'PENDING'	Enum: PENDING (menunggu bayar) / PAID (lunas) / CANCELLED

					(dibatalkan) / EXPIRED (kedaluwarsa).

3.1.5 Tabel Pembayaran

- **Identifikasi/Nama:** pembayaran
- **Deskripsi Isi:** Tabel log khusus rekonsiliasi finansial. Bertugas merekam token sesi Midtrans dan menampung waktu pelunasan yang divalidasi melalui jaringan *Webhook*.
- **Jenis:** Tabel Data Log Transaksi
- **Volume:** Sinkron 1:1 dengan tabel pesanan.
- **Laju:** Menyesuaikan penyelesaian transaksi di gerbang perbankan.
- **Primary Key:** id_pembayaran

Id Field	**Deskripsi**	**Tipe & Length**	**Boleh NULL**	**Default**	**Keterangan**
id_pembayaran	Identitas pembayaran	VARCHAR(36)	NO	UUIDv4	Kunci primer UUID.
id_pesanan	Rujukan pesanan	VARCHAR(36)	NO	-	*Foreign Key* ke pesanan.
metode	Instrumen bank	VARCHAR(50)	YES	NULL	Cth: GoPay, BCA VA.
snap_token	Token antarmuka	VARCHAR(255)	NO	-	Digunakan memanggil UI Midtrans.
waktu_lunas	Penanda pelunasan	TIMESTAMP	YES	NULL	Diisi otomatis saat status lunas.

3.1.6 Tabel Pengiriman

- **Identifikasi/Nama:** pengiriman
- **Deskripsi Isi:** Tabel entitas manifest logistik yang mengikat alamat tujuan pesanan dengan identitas aktor Kurir penanggung jawab. Mencatat setiap pembaruan pergerakan fisik barang. **Jenis:** Tabel Data Logistik Operasional
- **Volume:** Sinkron 1:1 dengan tabel pesanan berstatus 'PAID'.
- **Laju:** Dimutakhirkan secara berkala oleh aktor Kurir di lapangan.
- **Primary Key:** id_pengiriman

Id Field	**Deskripsi**	**Tipe & Length**	**Boleh NULL**	**Default**	**Keterangan**
id_pengiriman	Identitas manifest	VARCHAR(36)	NO	UUIDv4	Kunci primer UUID.
id_pesanan	Rujukan pesanan	VARCHAR(36)	NO	-	*Foreign Key* ke pesanan.
id_kurir	Petugas pengantar	VARCHAR(36)	YES	NULL	*Foreign Key* ke users (Kurir).
alamat_tujuan	Titik koordinat/teks	TEXT	NO	-	Alamat spesifik pembeli.
status_kirim	Transisi fisik	VARCHAR(50)	NO	'DIKEMAS'	Status: DIKEMAS, DIKIRIM, DITERIMA.

3.2 Deskripsi Proses Secara Rinci

Bagian ini menguraikan setiap antarmuka pemrograman aplikasi (API) sesuai dengan pemodelan aliran sistem pada rancangan global . Spesifikasi layar (*UI Specification*) dalam dokumen ini diproyeksikan sebagai muatan data jaringan (*Network Payload*) untuk menyesuaikan standar rekayasa aplikasi web modern.

3.2.1 Spesifikasi Proses: Autentikasi Pengguna (Login API)

Identifikasi/Nama: Modul Pintu Masuk dan Keamanan Sesi Berbasis Token **Deskripsi Isi:** Titik akhir (*endpoint*) yang memfasilitasi pengguna untuk memvalidasi identitas. Peladen membandingkan masukan dengan enkripsi *bcrypt* dan menerbitkan sesi *JSON Web Token* (JWT) . **Jenis:** RESTful API Endpoint HTTP

3.2.1.1 Spesifikasi Tabel Input

- Tabel users (Murni operasi *Read-Only* untuk pencocokan data).

3.2.1.2 Spesifikasi Tabel Output

TIDAK ADA modifikasi tabel di basis data. Namun, LoggerMiddleware secara implisit mencatat entri log ke sistem logging peladen (bukan ke tabel basis data aplikasi) berisi: alamat IP klien, timestamp percobaan masuk, dan status sukses/gagal. Hal ini merupakan perilaku audit infrastruktur, bukan output fungsional endpoint.

3.2.1.3 Spesifikasi Layar Utama (Endpoint API) Mengingat arsitektur terpisah (*Decoupled*), layar utama direpresentasikan oleh titik akses jaringan:

- **Metode Jaringan:** POST
- **Rute URL:** /api/v1/auth/login
- **Otorisasi:** Rute publik (Bebas diakses tanpa token JWT).

3.2.1.4 Spesifikasi Query

- GORM Query: SELECT * FROM users WHERE email = ? LIMIT 1; (Parameter ? mencegah Injeksi SQL)

3.2.1.5 Spesifikasi Field Data Pada Layar (JSON Payload)

Klien mengirimkan muatan data masukan sebagai berikut:

- email: String (Wajib memuat format surel sah).
- password: String (Wajib, panjang minimum 8 karakter keamanan)

3.2.1.6 Spesifikasi Function Key / Objek Pada Layar (Middleware)

Fungsi tombol atau objek kontrol direpresentasikan oleh perantara sistem (*Middleware*):

- **LoggerMiddleware:** Komponen yang mencatat alamat IP pengguna dan waktu percobaan masuk untuk keperluan audit pelacakan anomaly.

3.2.1.7 Spesifikasi Layar Pesan (API Response)

- **Pesan Sukses:** Mengembalikan kode HTTP 200 OK dengan format JSON berisi atribut token JWT.
- **Pesan Gagal:** Mengembalikan kode HTTP 401 Unauthorized jika kredensial salah atau tidak ditemukan.

Contoh Response Sukses (200 OK):

```
{
  "status": "success",
  "message": "Login berhasil",
  "data": {
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
    "role": "pembeli",
    "expires_in": "24h"
  }
}
```

Contoh Response Gagal (401 Unauthorized):

```
{
  "status": "error",
  "message": "Email atau password salah"
}
```

3.2.1.8 Spesifikasi Proses / Algoritma

1. **Initial State (IS):** Ekstraksi muatan permintaan JSON (email, password) dari klien.
2. Lakukan kueri pencarian melalui GORM ke tabel users.

3. IF hasil nihil, hentikan rantai eksekusi dan kembalikan galat 401 Unauthorized.
4. ELSE (Surel ditemukan), eksekusi komputasi bcrypt.CompareHashAndPassword().
5. IF validasi kriptografi sandi gagal, kembalikan 401 Unauthorized.
6. Tanamkan identitas (id_user) dan kewenangan (role) ke dalam muatan klaim JWT.
7. Tandatangani menggunakan Kunci Rahasia (*Secret Key*) peladen dan atur batas kedaluwarsa 24 jam.
8. **Final State (FS):** Terbitkan JWT kepada klien dalam format balasan JSON (200 OK).

3.2.1.9 Spesifikasi State Chart

- TIDAK ADA (Sistem bersifat *stateless* dan tidak memiliki perilaku transisi status antarmuka visual yang kompleks).

3.2.1.10 Spesifikasi Report (Matriks Pengujian SQA)

- **Test Case (AUTH-01):** Percobaan masuk masif (*Brute-force*).
- **Ekspektasi Sistem:** Waktu respon algoritma *bcrypt* terbukti konstan di atas ambang batas 500ms untuk melumpuhkan serangan tebakan peretas.

Matriks Pengujian Detail (diperluas):

No TC	Skenario Uji	Precondition	Input / Aksi	Expected Result	Pass Criteria
AUTH-01	Login berhasil (Happy Path)	User terdaftar di DB	POST /api/v1/auth/login{"email":"user@test.com","password":"Pass1234"}	HTTP 200 OK + JWT token dalam response body	Status 200, ada field "token" dalam JSON
AUTH-02	Login gagal — password salah	User terdaftar di DB	POST /api/v1/auth/login{"email":"user@test.com","password":"SALAH"}	HTTP 401 Unauthorized, tidak ada token	Status 401, tidak ada field "token"
AUTH-03	Login gagal — email tidak ada	DB kosong / email tidak terdaftar	POST /api/v1/auth/login{"email":"tidakada@x.com","password":"Pass1234"}	HTTP 401 Unauthorized	Status 401, pesan error sesuai
AUTH-04	Brute-force protection (bcrypt)	Akun valid tersedia	10x percobaan login salah berturut-turut dalam 5 detik	Setiap percobaan membutuhkan waktu	Rata-rata response time >

				> 200ms karena bcrypt cost-14	200ms, tidak ada token bocor
AUTH-05	Akses endpoint protected tanpa token	Tidak ada token	GET /api/v1/products/123 tanpa header Authorization	HTTP 401 Unauthorized dari AuthMiddleware	Status 401, request tidak mencapai handler

3.2.2 Spesifikasi Proses: Manajemen Katalog & Kepemilikan (Khusus Supplier)

Identifikasi/Nama: Modul Ekosistem Hulu dan Validasi *Insecure Direct Object Reference* (IDOR)

Deskripsi Isi: Proses di mana aktor Supplier mengatur rincian panen mereka. Modul ini menerapkan proteksi lapis ganda validasi identitas .

Jenis: RESTful API Endpoint Transaksional

- 3.2.2.1 Spesifikasi Tabel Input: Tabel produk.
- 3.2.2.2 Spesifikasi Tabel Output: Tabel produk (Menjalankan operasi pembaruan dan penghapusan).
- 3.2.2.3 Spesifikasi Layar Utama (Endpoint API): Metode PUT dan DELETE menuju rute /api/v1/products/:id_produk.
- 3.2.2.4 Spesifikasi Query: UPDATE produk SET harga = ?, stok = ? WHERE id_produk = ? AND id_user = ?;
- 3.2.2.5 Spesifikasi Field Data Pada Layar (JSON Payload): nama_produk (String), harga (Numerik > 0), stok (Integer >= 0).
- 3.2.2.6 Spesifikasi Function Key (Middleware): AuthMiddleware dan RoleMiddleware khusus "supplier".
- 3.2.2.7 Spesifikasi Layar Pesan (API Response): Mengembalikan HTTP 200 OK jika berhasil.

Contoh Response Sukses Update Produk (200 OK):

```
{
  "status": "success",
  "message": "Produk berhasil diperbarui",
  "data": {
    "id_produk": "uuid-produk-xxx",
    "nama_produk": "Bayam Hijau Segar",
    "harga": 15000,
```

```
    "stok": 100
  }
}
```

Contoh Response IDOR Forbidden (403):

```
{
  "status": "error",
  "message": "Akses ditolak: Anda bukan pemilik produk ini"
}
```

- 3.2.2.8 Spesifikasi Proses / Algoritma: 1) Validasi Role "supplier". 2) Ekstrak id_user dari JWT. 3) Cari target id_produk. 4) Jika pemilik tabel tidak cocok dengan sesi (IDOR), lempar 403 Forbidden. 5) Jika cocok, perbarui data.

TIDAK ADA. Modul Manajemen Katalog bersifat CRUD murni tanpa transisi status internal. Perubahan produk (harga, stok) langsung tersimpan ke tabel produk tanpa alur state.

- 3.2.2.10 Spesifikasi Report (Matriks Pengujian SQA): Test Case CAT-01 (Uji IDOR lintas Supplier).

Matriks Pengujian Detail (diperluas):

No TC	Skenario Uji	Precondition	Input / Aksi	Expected Result	Pass Criteria
CAT-01	Update produk sendiri (Happy Path)	Login sebagai Supplier A, produk P milik A	PUT /api/v1/products/{id_produk_A}{"harga":15000,"stok":100}	HTTP 200 OK, data produk terupdate	Status 200, stok dan harga berubah di DB
CAT-02	IDOR — update produk Supplier lain	Login sebagai Supplier B, produk P milik Supplier A	PUT /api/v1/products/{id_produk_A}{"harga":1}	HTTP 403 Forbidden, data tidak berubah	Status 403, data produk A tetap di DB
CAT-03	Update produk stok negatif	Login sebagai Supplier, produk valid	PUT /api/v1/products/{id}{"stok":-10}	HTTP 400 Bad Request, validasi gagal	Status 400 atau 422, stok tidak berubah
CAT-04	Tambah produk baru oleh Supplier	Login sebagai Supplier	POST /api/v1/products{"nama_produk":"Bayam","harga":5000,"stok":50}	HTTP 201 Created, produk tersimpan dengan id_user Supplier	Status 201, id_user pada produk = id Supplier login

3.2.3 Spesifikasi Proses: Checkout dan Penguncian Stok ACID (Khusus Pembeli)

Identifikasi/Nama: Modul Resolusi Transaksi Komersial ACID

Deskripsi Isi: Modul finansial ekstrem yang mengubah antrean keranjang menjadi pesanan riil menggunakan *Row-level Locking* . Jenis: RESTful API Endpoint Komputasi Berat

- 3.2.3.1 Spesifikasi Tabel Input: Tabel keranjang dan produk.
- 3.2.3.2 Spesifikasi Tabel Output: Tabel pesanan, pembayaran (Insert), keranjang (Delete), produk (Update).

- 3.2.3.3 Spesifikasi Layar Utama (Endpoint API): Metode POST rute /api/v1/orders/checkout.
- 3.2.3.4 Spesifikasi Query: SELECT stok FROM produk WHERE id_produk = ? FOR UPDATE;
- 3.2.3.5 Spesifikasi Field Data Pada Layar (JSON Payload): TIDAK ADA (Identitas mutlak diambil dari JWT Header).
- 3.2.3.6 Spesifikasi Function Key (Middleware): RecoveryMiddleware (mencegah *server crash*).
- 3.2.3.7 Spesifikasi Layar Pesan (API Response): HTTP 201 Created beserta token Midtrans.

Contoh Response Sukses Checkout (201 Created):

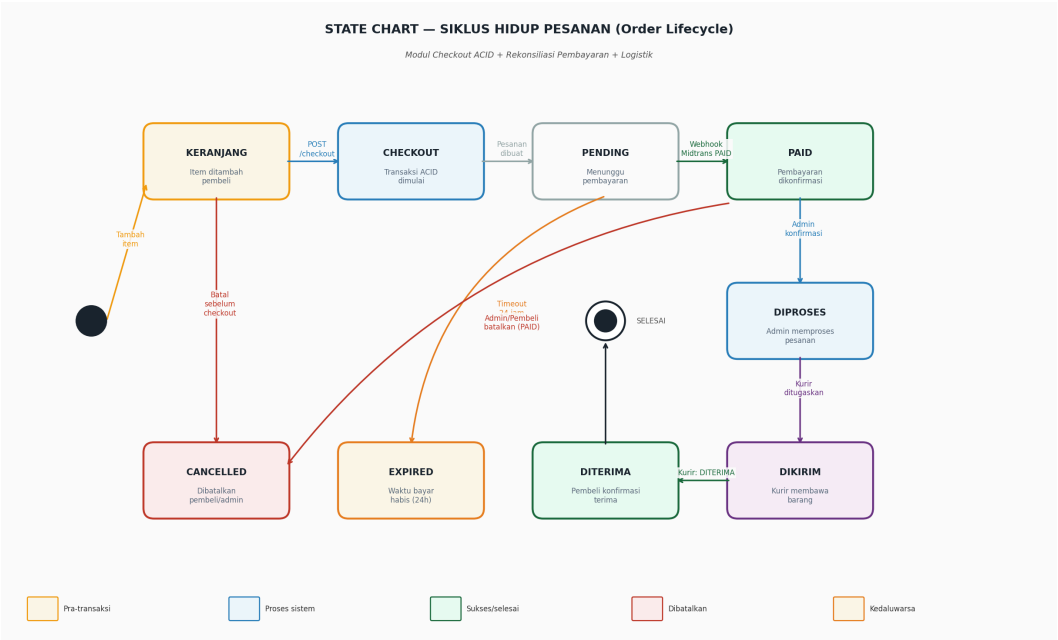
```
{
  "status": "success",
  "message": "Pesanan berhasil dibuat",
  "data": {
    "id_pesanan": "uuid-pesanan-xxx",
    "total_tagihan": 75000,
    "status_pesanan": "PENDING",
    "snap_token": "snap-token-midtrans-xxx",
    "redirect_url": "https://app.midtrans.com/snap/v2/vtweb/snap-token"
  }
}
```

Contoh Response Stok Habis (400 Bad Request):

```
{
  "status": "error",
  "message": "Stok produk tidak mencukupi",
  "data": {
    "id_produk": "uuid-produk-xxx",
    "stok_tersedia": 2,
    "stok_diminta": 5
  }
}
```

- 3.2.3.8 Spesifikasi Proses / Algoritma: 1) Mulai tx.Begin(). 2) Kueri FOR UPDATE. 3) Jika stok kurang, tx.Rollback(). 4) Kalkulasi total. 5) Minta token Midtrans. 6) Simpan Pesanan. 7) Hapus Keranjang. 8) tx.Commit().

State chart berikut menggambarkan seluruh siklus hidup (lifecycle) pesanan sejak keranjang diisi hingga barang diterima oleh pembeli, termasuk jalur pembatalan dan kedaluwarsa:



Gambar 3.2.3.9 — State Chart Siklus Hidup Pesanan (Order Lifecycle)

Penjelasan transisi kritis:

PENDING → PAID: Dipicu oleh Webhook Midtrans dengan validasi SHA-512. Transisi atomik bersama pembuatan record di tabel pembayaran.

PAID → CANCELLED: Hanya dapat dilakukan oleh Admin atau Pembeli selama barang belum berstatus DIKIRIM. Sistem wajib memproses refund ke Midtrans.

PENDING → EXPIRED: Sistem menjalankan scheduled job setiap jam untuk mendeteksi pesanan yang melewati batas 24 jam tanpa konfirmasi pembayaran.

- 3.2.3.10 Spesifikasi Report (Matriks Pengujian SQA): Test Case CHK-01 (Pengujian stres konkurensi / *Race Condition*).

Matriks Pengujian Detail (diperluas):

No TC	Skenario Uji	Precondition	Input / Aksi	Expected Result	Pass Criteria
CHK-01	Checkout berhasil (Happy Path)	Pembeli login, keranjang terisi, stok cukup	POST /api/v1/orders/checkout (JWT Header)	HTTP 201 Created, snap_token Midtrans returned, stok berkurang	Status 201, pesanan tersimpan, keranjang kosong, stok berkurang
CHK-02	Checkout stok habis	Pembeli login, keranjang berisi 10 barang, stok hanya 5	POST /api/v1/orders/checkout	HTTP 400/422, rollback, stok tidak berubah	Status 4xx, stok tetap 5, tidak ada pesanan dibuat
CHK-03	Race Condition — 50 user checkout bersamaan	Stok produk = 10, 50 user concurrent checkout qty=1	k6: 50 VU POST /api/v1/orders/checkout secara bersamaan	Hanya 10 pesanan sukses (201), 40 lainnya gagal	Jumlah sukses = 10, stok akhir = 0, tidak ada overselling

				(400/422), stok tidak pernah < 0	
CHK-04	Checkout keranjang kosong	Pembeli login, keranjang kosong	POST /api/v1/orders/checkout	HTTP 400 Bad Request	Status 400, tidak ada pesanan dibuat

3.2.4 Spesifikasi Proses: Rekonsiliasi Pembayaran (Webhook Midtrans)

Identifikasi/Nama: Modul Rekonsiliasi Finansial Asinkronus Deskripsi Isi: Otomasi *Server-to-Server* di mana Midtrans mengirimkan HTTP POST. Dilindungi validasi SHA-512 . Jenis: RESTful API Endpoint (Webhook)

- 3.2.4.1 Spesifikasi Tabel Input: TIDAK ADA (Muatan dari eksternal).
- 3.2.4.2 Spesifikasi Tabel Output: Tabel pesanan dan pembayaran (Pembaruan status).
- 3.2.4.3 Spesifikasi Layar Utama (Endpoint API): Metode POST rute /api/v1/payments/webhook.
- 3.2.4.4 Spesifikasi Query: UPDATE pesanan SET status_pesanan = 'PAID' WHERE id_pesanan = ?;
- 3.2.4.5 Spesifikasi Field Data Pada Layar (JSON Payload): order_id, status_code, gross_amount, signature_key.
- 3.2.4.6 Spesifikasi Function Key (Middleware): RecoveryMiddleware.
- 3.2.4.7 Spesifikasi Layar Pesan (API Response): HTTP 200 OK (Penerimaan mutlak).

Contoh Response Webhook Diterima (200 OK):

```
{
  "status": "success",
  "message": "Pembayaran dikonfirmasi",
  "data": {
    "id_pesanan": "uuid-pesanan-xxx",
    "status_pesanan": "PAID",
    "metode": "gopay",
    "waktu_lunas": "2026-03-07T10:30:00Z"
  }
}
```

Contoh Response Signature Invalid (403 Forbidden):

```
{
  "status": "error",
  "message": "Signature key tidak valid"
}
```

- 3.2.4.8 Spesifikasi Proses / Algoritma: 1) Terima JSON Midtrans. 2) Rangkai order_id+status+gross+ServerKey. 3) *Hash* SHA-512. 4) Bandingkan dengan signature_key. 5) Jika beda tolak. 6) Jika sama perbarui status pesanan menjadi PAID.

State chart modul pembayaran terintegrasi dengan siklus hidup pesanan. Lihat Gambar 3.2.3.9 untuk diagram lengkap. Secara spesifik, transisi yang dipicu modul ini:
tabel pembayaran: record dibuat saat PENDING, kolom waktu_lunas diisi saat transisi ke PAID.
Idempotency: Jika Webhook diterima ganda untuk pesanan yang sudah PAID, sistem mengembalikan 200 OK tanpa duplikasi record (idempotent handler).

- 3.2.4.10 Spesifikasi Report (Matriks Pengujian SQA): Test Case PAY-01 (Simulasi penolakan *Signature Key* palsu).

Matriks Pengujian Detail (diperluas):

No TC	Skenario Uji	Precondition	Input / Aksi	Expected Result	Pass Criteria
PAY-01	Webhook valid dari Midtrans (Happy Path)	Pesanan berstatus PENDING	POST /api/v1/payments/webhook{order_id, status_code:"200", gross_amount, signature_key VALID}	HTTP 200 OK, status pesanan → PAID, waktu_lunas terisi	Status 200, status_pesanan di DB = PAID
PAY-02	Webhook dengan Signature Key palsu	Pesanan berstatus PENDING	POST /api/v1/payments/webhook{signature_key: "PALSU123"}	HTTP 403 Forbidden atau 400, status pesanan tidak berubah	Status 4xx, status_pesanan tetap PENDING
PAY-03	Webhook duplikat (idempotency)	Pesanan sudah berstatus PAID	POST /api/v1/payments/webhook (dikirim 2x dengan data sama)	HTTP 200 OK (tidak error), data tidak duplikasi	Status 200, hanya 1 record pembayaran di DB

3.2.5 Spesifikasi Proses: Manajemen Logistik (Khusus Kurir)

Identifikasi/Nama: Modul Pelacakan Ekspedisi Fisik dan Validasi IDOR

Deskripsi Isi: Pembaruan titik koordinat fisik barang oleh Kurir sah . Jenis: RESTful API Endpoint

- 3.2.5.1 Spesifikasi Tabel Input: Tabel pengiriman.
- 3.2.5.2 Spesifikasi Tabel Output: Tabel pengiriman (Update kolom status_kirim).
- 3.2.5.3 Spesifikasi Layar Utama (Endpoint API): Metode PATCH rute /api/v1/shipping/:id_pengiriman/status.
- 3.2.5.4 Spesifikasi Query: UPDATE pengiriman SET status_kirim = ? WHERE id_pengiriman = ? AND id_kurir = ?;
- 3.2.5.5 Spesifikasi Field Data Pada Layar (JSON Payload): status_kirim (Enum: DIKEMAS, DIKIRIM, DITERIMA).
- 3.2.5.6 Spesifikasi Function Key (Middleware): RoleMiddleware khusus "kurir".

- 3.2.5.7 Spesifikasi Layar Pesan (API Response): HTTP 200 OK.

Contoh Response Sukses Update Status (200 OK):

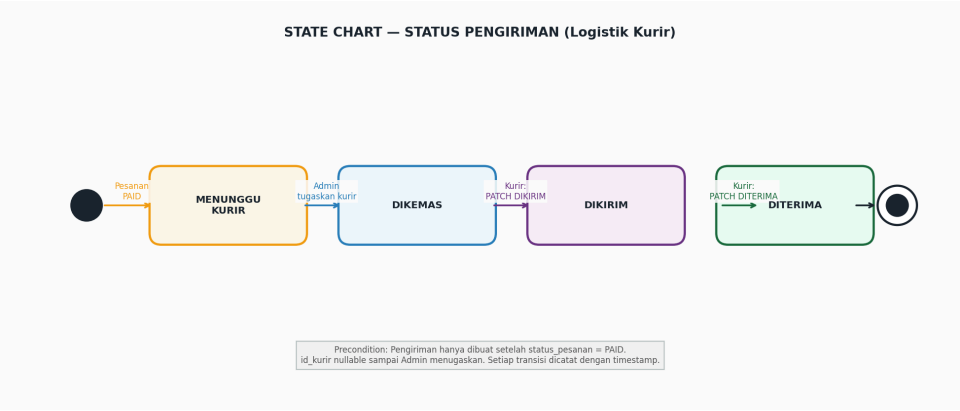
```
{
  "status": "success",
  "message": "Status pengiriman diperbarui",
  "data": {
    "id_pengiriman": "uuid-pengiriman-xxx",
    "status_kirim": "DIKIRIM",
    "updated_at": "2026-03-07T14:00:00Z"
  }
}
```

Contoh Response IDOR Kurir Lain (403 Forbidden):

```
{
  "status": "error",
  "message": "Akses ditolak: Anda tidak ditugaskan pada pengiriman ini"
}
```

- 3.2.5.8 Spesifikasi Proses / Algoritma: 1) Validasi Role Kurir. 2) Cari manifes pengiriman. 3) Jika id_kurir di database tidak sama dengan pemohon, blokir dengan 403 Forbidden (Cegah IDOR antar kurir). 4) Jika sama, perbarui status.

State chart berikut menggambarkan transisi status fisik pengiriman yang dikelola oleh aktor Kurir:



Gambar 3.2.5.9 — State Chart Status Pengiriman (Logistik Kurir)

Status MENUNGGU KURIR dibuat otomatis saat status_pesanan berubah ke PAID. Hanya Kurir yang ditugaskan (id_kurir === JWT id_user) yang dapat memperbarui status.

- 3.2.5.10 Spesifikasi Report (Matriks Pengujian SQA): Test Case SHP-01 (Pengujian Penetrasi Otorisasi Silang Kurir).

Matriks Pengujian Detail (diperluas):

No TC	Skenario Uji	Precondition	Input / Aksi	Expected Result	Pass Criteria
SHP-01	Update status pengiriman sendiri (Happy Path)	Kurir A login, manifest M ditugaskan ke A	PATCH /api/v1/shipping/{id_M}/status{"status_kirim":"DIKIRIM"}	HTTP 200 OK, status_kirim = DIKIRIM	Status 200, status berubah di DB

SHP-02	IDOR — Kurir B update manifest Kurir A	Kurir B login, manifest M milik Kurir A	PATCH /api/v1/shipping/{id_M}/status{"status_kirim":"DITERIMA"}	HTTP 403 Forbidden, status tidak berubah	Status 403, status manifest A tidak berubah di DB
SHP-03	Update status dengan value tidak valid	Kurir login, manifest valid	PATCH /api/v1/shipping/{id}/status{"status_kirim":"HILANG"}	HTTP 400 Bad Request, value di luar enum	Status 400, status tidak berubah

3.3 Dekomposisi Fisik Modul

Bagian ini menjabarkan dekomposisi "fisik" dari struktur direktori kode sumber yang mengimplementasikan paradigma *Clean Architecture* pada bahasa pemrograman Golang. Dekomposisi ini memisahkan fungsionalitas sistem ke dalam modul-modul yang independen untuk mempermudah proses pemeliharaan (*maintenance*) dan pengujian unit (*Unit Testing*) .

Nama Direktori Fisik	**Nama File**	**Nama Modul**	**Nama Fungsi**	**Keterangan Fisik & Logis**
/internal/domain	user.go	Domain Layer	Pendefinisian Struct	Menyimpan entitas data murni dan *Interface* kontrak relasional tanpa logika operasional.
/internal/delivery/http	order_handler.go	Delivery Layer	CheckoutHandler()	Pengendali API; bertugas memvalidasi JSON masuk dan mengemas

				format respons HTTP.
/internal/usecase	order_usecase.go	Usecase Layer	ProcessCheckout()	Otak komputasi bisnis; mengeksekusi kalkulasi transaksi dan validasi ketersediaan stok aktual.
/internal/repository	product_repo.go	Repository Layer	UpdateStokTx()	Adaptor basis data; mengeksekusi sintaks kueri GORM menuju mesin PostgreSQL.
/pkg/jwt	jwt.go	Utility Library	GenerateToken()	Pustaka eksternal murni untuk enkripsi dan dekripsi *JSON Web Token*.
/cmd/api	main.go	Entry Point	main()	Titik mula *binary* peladen; membaca

				konfigurasi *environment* dan menyalakan *framework* Gin.